

PRIVACY REPORT



2025년 제6호
개인정보 월간동향분석

PRIVACY REPORT

2025년
개인정보
월간동향분석

CONTENTS

1

캘리포니아: 소비자 개인정보보호 규정 개정안 검토

2

미국: 인공지능 거버넌스 법제 동향

정책/제도

캘리포니아: 소비자 개인정보보호 규정 개정안 검토

[목 차]

1. CCPA 개정안 개요 및 추진 배경

- (1) 캘리포니아 개인정보 보호 환경 변화
- (2) 개정안 추진 경위 및 공식 위원회 회의 결과
- (3) 2025년 공공 의견 수렴 절차 및 주요 쟁점

2. 자동화된 의사결정 기술(ADMT) 규제 세부 내용

- (1) ADMT의 정의 및 적용 대상 기술 사례
- (2) 자동화 기술 활용에 따른 사전 위험 평가 절차
- (3) 소비자 고지 의무 및 권리 보호 방안 강화

3. 위험 평가 및 사이버보안 감사 의무화

- (1) 민감정보 대규모 처리 기업 및 매출 기준 설정
- (2) 연간 위험 평가 및 사이버보안 감사 보고 요구사항
- (3) 위험 평가·보안 감사 적용 범위 및 기업 준비 전략

4. 커넥티드 디바이스 및 증강·가상 현실(AR/VR) 서비스 개인정보 고지 기준 강화

- (1) 개인정보 수집·이용 시점 및 고지 절차 구체화
- (2) 시각적 UI, 음성, 햅틱 등 다양한 고지 수단 적용 방안
- (3) 아동 및 미성년자 대상 서비스의 보호자 동의 및 고지 강화

5. CCPA 개정안이 기업 개인정보 거버넌스에 미치는 영향 및 대응 전략

- (1) 자동화 기술 도입과 개인정보 보호 거버넌스 변화 분석
- (2) 기업의 법적·기술적 책임 강화 및 내부 정책 개선 방안
- (3) 향후 CCPA 규제 동향 전망과 기업 대응 전략

1. CCPA 개정안 개요 및 추진 배경

(1) 캘리포니아 개인정보 보호 환경 변화

■ 캘리포니아는 미국 내에서 가장 강력한 개인정보 보호법을 선도하는 주로서, 기술 발전과 소비자 권리 강화를 위한 법제 개선 수요가 지속적으로 제기되고 있음.

- 디지털 경제 확산에 따라 민감정보 수집·이용이 증가하면서, 데이터 기반 자동화 기술과 관련된 프라이버시 침해 우려도 함께 확대됨.
 - 인공지능 기반 대출 심사, 자동 채용 필터링, 얼굴 인식 출입 시스템, 음성비서 등 자동화된 의사결정 기술의 일상화로 인해 소비자 권리와 생활에 직접적인 영향 발생.
 - 위치정보, 생체정보, 행태정보 등 고위험 개인정보의 수집·처리가 증가함에 따라 기존 고지 및 동의 절차만으로는 소비자 통제권 확보에 한계 존재.
 - 아동·청소년이 주로 이용하는 소셜미디어와 게임 등 디지털 플랫폼에서 연령 확인 기능 부재로 인한 프라이버시 침해 사례 다수 발생.
 - 대형 플랫폼 기업이 다양한 서비스를 통합 운영함에 따라 기존의 ‘서비스 단위 고지’ 체계로는 정보 제공의 실효성 확보에 어려움 존재.
- 규제 공백 해소 및 글로벌 기준 부합을 위한 제도 정비 필요성 증가
 - 미국은 연방 차원의 포괄적 개인정보 보호법이 부재한 상황으로, 캘리포니아는 사실상 국가 수준의 기준 역할을 수행
 - EU의 GDPR 및 디지털서비스법(Digital Services Act, DSA)¹⁾ 등 국제 규제 체계와의 정합성을 고려한 제도 개편 필요
 - 소비자 데이터 주권 보장을 위한 설명 가능성, 자동화 결정 거부권, 권리 행사 수단 등 권리 중심 규제 도입 필요
 - 기술 변화 속도를 반영한 유연하고 동적인 규제 체계(dynamic regulation)로의 전환 필요성 대두

(2) 개정안 추진 경위 및 공식 위원회 회의 결과

■ 2025년 5월 캘리포니아 개인정보 감독기관(California Privacy Protection Agency, CPPA)²⁾은 정례 회의를 통해 새로운 규제 방향을 담은 개정안을 검토하고 주요 정책 방침을 공개함.

- 개정안 마련은 기술 자문, 실무 검토, 공청회 등을 포함한 단계별 과정을 통해 이루어짐.
 - 2023년 4월, 자동화된 의사결정 기술(Automated Decision-Making Technology, ADMT)³⁾ 규제 도입 필요성을 검토하기 위해 ‘기술규제 소위원회’ 구성
 - 2023년 10월, 커넥티드 디바이스 고지 방식에 대한 기술백서 발표 및 실증 워크숍 개최.

1) 디지털서비스법 (DSA, Digital Services Act): EU가 2022년에 제정한 법안으로, 온라인 플랫폼과 디지털 서비스 제공자의 책임을 강화하며 투명성 및 이용자 권리 보호를 목표로 함.

2) 캘리포니아 개인정보 감독기관 (California Privacy Protection Agency, CPPA): 캘리포니아 주정부 산하 독립 규제기관으로, CCPA의 집행과 개정을 총괄하며 소비자 개인정보 보호를 강화하는 역할을 수행함.

3) 자동화된 의사결정 기술 (Automated Decision-Making Technology, ADMT): AI, 머신러닝, 규칙 기반 알고리즘 등을 활용해 인적 개입 없이 자동으로 의사결정을 수행하는 기술군을 의미함.

- 2024년 6월, 연령확인 기술의 정확성 및 프라이버시 침해 가능성에 대한 개인정보 영향 평가(Privacy Impact Assessment, PIA)⁴⁾ 초안 공개.
 - 2025년 3월, 개정안 초안이 확정되어 CPPA 이사회에 보고됨.
 - 2025년 5월, 정례 위원회에서 정식 심의를 거쳐 개정안 초안이 승인되고, 공공 의견 수렴 절차가 시작됨.
- CPPA 위원회는 개정안의 실효성, 수용성, 국제 정합성을 종합적으로 검토하여 핵심 개정사항을 결정함.
 - ADMT에 대한 정의를 신설하고, 적용 범위 및 기업의 고지 의무를 명문화함.
 - 민감정보를 대규모로 처리하거나 일정 매출 이상인 기업에 대해 연간 위험 평가 및 사이버보안 감사 의무를 부과함.
 - AR/VR, 웨어러블 기기 등 물리적 화면이 없는 환경에 대응할 수 있도록 음성·촉각·시각적 이용자 인터페이스(UI) 기반 고지 방식을 제도화함.
 - 연령 확인 기술 도입 시 정확성, 편향성, 설명 가능성 등의 기준을 마련하고, 대체 수단 제공 의무를 부과함.
 - 규제의 실질 적용 가능성을 고려해 2026년 시범 도입, 2027년 일부 시행, 2028년 전면 적용의 3단계 로드맵을 제시함.

(3) 2025년 공공 의견 수렴 절차 및 주요 쟁점

■ CCPA 개정안 초안은 2025년 6월 중순부터 45일간의 공공 의견 수렴 절차에 들어갔으며, 기술기업, 시민단체, 학계 등 다양한 이해관계자의 참여 속에 주요 쟁점에 대한 논의가 활발하게 진행됨.

- CPPA는 다양한 방식으로 의견을 수렴하며, 제도 정비 과정의 투명성과 수용성을 제고함.
 - 2025년 6월 17일부터 8월 1일까지 CPPA 공식 홈페이지 내 전자 의견 제출 시스템을 통해 누구나 조항별 의견을 등록할 수 있도록 개방형 플랫폼을 운영함.
 - 대면 공청회는 로스앤젤레스, 샌프란시스코, 새크라멘토 등 주요 도시에서 지역별로 개최되었으며, 온라인 청취도 병행하여 지원함.
 - 기술기업을 위한 정책설명회, 시민단체 초청 간담회, 중소기업 전용 Q&A 세션 등 맞춤형 피드백 프로그램을 별도로 진행함.
 - 의견 접수 시 ‘찬성·반대’ 이외에도 조문별 개선안, 예상 부작용, 대체 규제안 등 구체적인 제안을 제출할 수 있도록 양식을 구성함.

4) 개인정보 영향평가(PIA): 새로운 기술이나 시스템이 개인정보에 미치는 영향을 사전에 분석하고 대응 방안을 마련하는 제도

- 의견 수렴 과정에서 다음과 같은 주요 쟁점이 집중적으로 논의됨.
 - ADMT의 정의가 포괄적으로 규정되어 있어, 단순 알고리즘 기반 추천 기능까지 규제 대상에 포함될 가능성에 대한 우려 제기
 - 중소기업의 현실을 반영하지 않은 연간 위험 평가 및 사이버보안 감사 의무화에 대해 과도한 규제라는 비판 제기
 - 커넥티드 디바이스, 웨어러블 등 비(非)디스플레이 환경에서 고지 의무 이행을 위한 기술적·이용자 경험(UX)적 대안의 필요성 부각
 - 생체정보 기반 연령 추정 기술의 정확도 부족 및 인종·성별 편향으로 인한 오탐 가능성과 프라이버시 침해 우려 제기
 - 과도한 고지 및 설명 의무가 이용자 경험을 저해하고, 정보 피로(information fatigue)⁵⁾를 유발할 수 있다는 실무적 비판 제기

2. 자동화된 의사결정 기술(ADMT) 규제 세부 내용

(1) ADMT의 정의 및 적용 대상 기술 사례

■ ADMT는 인공지능, 머신러닝, 규칙 기반 알고리즘 등을 활용해 소비자의 개인정보를 기반으로 인적 개입 없이 결정이나 판단을 내리는 모든 기술을 포괄함.

- ADMT의 정의 확장은 기술 발전과 활용 범위 확대에 따라 계속 진행 중임.
 - 금융 서비스에서는 AI가 신용 점수를 산출하거나 대출 가능 여부를 판단함.
 - 채용 과정에서는 이력서 스크리닝과 지원자 평가의 자동화를 수행함.
 - 온라인 플랫폼에서는 맞춤형 광고 추천과 개인화 콘텐츠 큐레이션을 제공함.
 - 얼굴·지문·음성 등 생체정보 인식 기반 출입 통제 및 이용자 인증 시스템이 적용됨.
 - 의료 분야에서는 진단 보조, 위험도 평가, 맞춤형 치료 권고 시스템으로 활용됨.
 - 보험사의 위험 평가 및 가격 책정, 유통업체의 수요 예측과 재고 관리 자동화 시스템이 확대됨.
- 개정안은 ADMT의 범위를 명확히 하여 다음과 같은 기준으로 규제 대상 여부를 판단함.
 - 의사결정 결과가 소비자의 권리·이익·서비스 접근성에 실질적인 영향을 미치는지 여부
 - 결정 과정의 투명성, 설명 가능성, 편향성 등의 위험 평가가 필요한 핵심 시스템 여부
 - 단순 정보 제공 또는 콘텐츠 추천 등 영향이 제한적인 시스템은 규제 대상에서 제외함

5) 정보 피로(information fatigue): 과도한 정보 제공으로 인한 피로 및 인지 저하 현상

(2) 자동화 기술 활용에 따른 사전 위험 평가 절차

■ ADMT 도입 전, 기업은 해당 기술이 초래할 수 있는 개인정보 보호 및 차별 위험을 체계적으로 평가하고 관리해야 함.

- 사전 위험 평가는 알고리즘 설계, 데이터 수집 및 처리, 결과 영향 등을 전방위적으로 검토함.
 - 알고리즘 편향성(Bias) 및 차별 가능성 평가: 성별, 인종, 연령 등 민감 속성에 따른 부당한 차별 요소를 진단함.
 - 데이터 정확성과 품질 검증: 오류 또는 왜곡된 데이터로 인한 잘못된 의사결정을 방지함.
 - 개인정보 유출 및 노출 위험 분석: 데이터 저장 및 전송 과정에서 발생할 수 있는 보안 취약점을 식별함.
 - 의사결정의 투명성과 설명 가능성 점검: 소비자가 결정 과정을 이해할 수 있도록 기술적·절차적 방안을 검토함.
 - 위험도에 따른 대응책 및 개선 계획 수립: 위험 최소화를 위한 정책 수립 및 기술 보완책을 마련함.
- 위험 평가 결과는 내부 문서로 작성되어야 하며, 감독기관 요청 시 제출 및 검증 대상임.
 - 평가 주기는 ADMT의 설계 또는 운영 변경 시마다 수행하도록 규정함.
 - 기업은 평가 결과를 바탕으로 위험 완화 방안을 실행하고, 그 이행 현황을 지속적으로 모니터링해야 함.
 - 사전 위험 평가는 인공지능 윤리와 개인정보 보호의 핵심 방어선으로 작용하며, 법적 책임 소재 규명에도 활용됨.

(3) 소비자 고지 의무 및 권리 보호 방안 강화

■ 개정안은 ADMT 활용 시 소비자에게 충분하고 명확한 정보를 제공하고, 권리 행사를 보장하기 위한 구체적인 조치를 규정함.

- 고지 의무는 다음 내용을 포함하며, 다양한 매체와 인터페이스를 통해 전달해야 함.
 - ADMT 도입 목적과 작동 원리 개요 설명
 - 처리되는 개인정보의 유형과 목적에 대한 상세 안내
 - 자동화된 결정이 소비자의 권리, 서비스 접근성, 재정적 결과 등에 미치는 영향 명시
 - 소비자가 자동화된 결정에 대해 거부하거나 이의를 제기할 수 있는 권리 및 절차 안내

- 연락처 및 지원 창구 정보 제공
- 고지는 텍스트뿐 아니라 증강·가상 현실(AR/VR)⁶⁾, 음성 안내, 햅틱(Haptic) 촉각 등 다양한 인터페이스를 활용하여, 특히 비 시각적 환경에서도 접근성을 보장함.
 - 웨어러블 기기, 스마트 스피커, 가상현실 플랫폼 등 특수 환경에 맞는 고지 방식 도입을 권장함.
 - 고지 내용은 비전문가도 이해할 수 있도록 평이한 언어와 시각화 요소를 활용함.
- 소비자 권리 보호는 ADMT의 투명성과 책임성을 강화하며, 소비자 신뢰 회복과 공정한 기술 활용을 뒷받침함.
 - 자동화된 결정 결과에 대해 소비자가 이의를 제기할 권리를 보장함.
 - 이의 제기 시 인간 심사자의 재검토 제공 의무를 부과함.
 - 재검토 절차 및 결과 통보의 투명성을 확보함.
 - 이의 제기 과정에서 차별 금지 및 개인정보 보호 원칙의 철저한 준수를 의무화함.
 - 소비자의 결정 권한 확대를 위한 선택권 및 거부권을 명시함.

3. 위험 평가 및 사이버보안 감사 의무화

(1) 민감정보 대규모 처리 기업 및 매출 기준 설정

■ 개정안은 민감정보를 대규모로 처리하거나 일정 수준 이상의 매출을 보유한 기업에 추가적인 위험 관리 책임을 부과함.

- 이는 기업 규모와 개인정보 처리량에 따른 위험 수준을 고려하여, 보다 정밀한 관리 체계를 도입하려는 취지임.
 - 연간 매출 2,500만 달러 이상이면서 개인정보 25만 건 또는 민감정보 5만 건 이상의 소비자 개인정보를 처리하는 기업이 주요 대상임.
 - 민감정보 범위는 건강, 위치, 생체인식, 인증, 성 정체성, 정치 성향 등 광범위한 항목을 포함함.
 - 고위험 기업으로 분류되면 별도의 위험 평가, 보안 감사, 보고 의무가 부과됨.

(2) 연간 위험 평가 및 사이버보안 감사 보고 요구사항

6) 증강현실·가상현실 (Augmented Reality / Virtual Reality, AR/VR): 현실 세계에 디지털 요소를 덧입히거나(AR), 완전히 가상 공간을 생성하여 몰입형 경험을 제공하는 기술로, 스마트글래스, VR 헤드셋 등 몰입형 기기를 통해 구현되며, 개인정보 수집 및 이용자 행동 추적 기능이 내재됨.

■ 대상 기업은 개인정보 보호 관점에서 연 1회 이상 위험 평가와 사이버보안 감사를 실시하고, 그 결과를 보존하거나 감독기관에 보고해야 함.

- 감사는 개인정보 수명주기(Personal Data Lifecycle)⁷⁾ 전반(수집, 저장, 제공, 파기)에 걸쳐 보안 위험을 식별하고, 개선 필요 여부를 판단함.
 - 위험 평가는 개인정보 침해 가능성, 기술적 보호 수단, 내부 접근 통제 수준 등을 종합적으로 검토함.
 - 사이버보안 감사는 외부 전문가에 의한 독립적 수행이 권장되며, 감사 보고서에는 식별된 취약점과 개선 조치를 포함해야 함.
 - CPPA는 보고 내용을 바탕으로 법 위반 여부를 판단하고, 필요한 경우 시정 명령 또는 제재를 부과할 수 있음.
- 위험 평가는 개인정보 처리 과정에서의 잠재적 위험과 취약점을 분석하고, 관리 및 완화 방안을 포함함.
 - 알고리즘 편향, 데이터 유출 가능성, 내부 권한 관리 미비, 시스템 취약점 등을 포괄적으로 점검함.
 - 평가 결과는 서면 보고서로 작성되며, 내부 정책 수립 및 이행의 근거로 활용됨.
 - 위험 평가는 ADMT 도입 시 사전 평가와 연계되어, 지속적인 리스크 관리 체계 구축에 기여함.
- 사이버보안 감사는 기술적·관리적 보안 통제의 적절성을 검증하는 절차임.
 - 침투 테스트, 취약점 스캐닝, 접근 통제, 로그 관리, 사고 대응 체계 점검 등을 포함함.
 - 감사 결과는 감독기관 제출 시 참고 자료가 되며, 기업의 보안 수준을 객관적으로 입증하는 근거가 됨.
 - 감사 주기는 연 1회 이상이며, 중대한 보안 사고 발생 시 추가 감사가 요구될 수 있음.

(3) 위험 평가·보안 감사 적용 범위 및 기업 준비 전략

■ CPPA는 개인정보 보호 제도의 실효성을 높이기 위해, 고위험 기업부터 단계적으로 감사 및 평가 의무를 강화하는 방향을 모색 중임.

- 의료, 금융, 통신 등 민감정보를 대량 처리하는 산업군과 대형 플랫폼 기업을 중심으로 개인정보 보호 조치의 이행 수준을 평가하고 있으며, 관련 제도 개선을 검토 중임.
 - 이들 기업에 대해서는 리스크 기반 감사 및 영향 평가 절차를 강화하는 방안이 논의되고 있음.

7) 개인정보 수명주기(Personal Data Lifecycle): 개인정보가 생성, 수집, 저장, 이용, 공유, 파기되는 전체 흐름을 관리하는 개념.

- 시범 적용 결과는 평가 기준 표준화, 평가 도구 개발, 기업 지원 가이드라인 마련 등에 반영될 예정임.
- CPPA는 개인정보 보호 규정의 적용 대상을 점진적으로 확대하고, 고위험 기업에 대한 법적 책임 수준도 단계적으로 강화할 방침임.
 - AI 기반 자동화 시스템을 도입하거나 플랫폼 서비스를 운영하는 기업이 규제 대상에 포함될 가능성이 있음.
 - 중소기업의 제도 대응 역량 강화를 위해 가이드라인 제공, 교육 자료 배포 등 지원 방안을 병행하고 있음.
 - 기업은 내부 감사체계 구축, 정책 매뉴얼 정비, 외부 자문기관 활용 등을 통해 체계적인 대응 기반을 마련할 필요가 있음.
- CPPA는 고위험 기업에 대해 연 1회 이상의 위험 평가 및 보안 감사 수행을 권고하고 있으며, 향후 관련 의무화 및 보고 체계 구축 여부에 대한 정책 논의를 이어가고 있음.
 - 감사는 개인정보 수명주기 전반에 걸친 기술적·관리적 통제 수준을 점검하는 절차로, 외부 전문가에 의한 독립적 수행이 권장됨.
 - 감독기관은 감사 결과 또는 기업 제출 자료를 바탕으로 이행 수준을 점검하고, 필요한 경우 시정 조치나 제재를 부과할 수 있음.
 - 개인정보 보호 강화를 위해 기업은 자발적인 리스크 평가 체계를 정비하고, 거버넌스 조직 및 대응 전략을 고도화할 필요가 있음.
- 기업의 매출 및 개인정보 처리 규모에 따라 일정 기준 이상의 기업이 2028년~2030년 사이 단계적으로 감사 의무를 이행하도록 규정함.
 - 2027년 1월 1일 기준, 2026년 연간 총수입이 1억 달러 초과: 2028년 4월 1일까지 완료
 - 2028년 1월 1일 기준, 2027년 연간 총수입이 5천만 달러 이상 ~ 1억 달러 이하: 2029년 4월 1일까지 완료
 - 2028년 연간 총수입이 5천만 달러 미만: 2030년 4월 1일까지 완료
- 2030년에는 전면 시행을 목표로 하여, 모든 기준 충족 기업이 위험 평가 및 보안 감사 의무를 준수하도록 함.
 - 감독기관은 연례 감사 보고서 수신 및 이행 여부 점검을 통해 제도의 정착을 촉진함.
 - 미이행 기업은 개선 명령, 시정 조치, 과징금 부과 등의 행정처분 대상이 됨.
 - 기업은 법적 리스크 최소화, 사회적 신뢰 확보, 소비자 보호 수준 강화를 위해 개인정보 거버넌스 체계 고도화가 요구됨.

- 기업의 준비 방향으로서는 다음과 같은 사항이 권장됨.

- 전사 차원의 개인정보 보호 전략 수립 및 거버넌스 조직 신설(CISO/CPO 역할 강화)
- 내부 보안 전문 인력 채용 또는 외부 보안 컨설팅 기관과의 상시 협력 체계 구축
- 자동화된 위험 평가 및 감사 플랫폼 도입과 모니터링 시스템 연계
- 모든 임직원 대상 정기적인 개인정보 보호 교육과 보안 인식 제고 프로그램 운영
- 위험 평가 및 감사 결과에 따른 연간 개선 계획 수립과 실행력 확보

4. 커넥티드 디바이스 및 증강·가상 현실(AR/VR) 서비스 개인정보 고지 기준 강화

(1) 개인정보 수집·이용 시점 및 고지 절차 구체화

■ 개정안은 커넥티드 디바이스 및 몰입형 서비스(AR/VR)에서의 개인정보 수집 및 이용 실태에 대응하기 위해, 정보 수집 시점에서의 고지 요건을 구체화하고 사전 정보 제공 의무를 명확히 규정함.

- 디바이스 사용 과정에서 수집되는 개인정보는 이용자의 자각 없이 실시간으로 생성·수집될 가능성이 높음.

- 예시로, 스마트글래스 착용 시 시선 추적, 증강현실(AR) 지도 앱에서의 위치·이동 경로 수집, 가상현실(VR) 콘텐츠 이용 시 생체 반응 정보 측정 등이 있음.
- 이처럼 비직접적 수단을 통해 수집되는 개인정보에 대해서는 고지 시점, 고지 방식, 수집 항목 및 이용 목적을 명확히 안내해야 함.
- 정보 수집 전 반드시 고지를 완료해야 하며, 사전 동의 없이 자동 수집되는 데이터는 최소한으로 제한되며, 서비스 제공에 필수적인 항목으로만 한정됨.
- 서비스 외 제3자와 개인정보를 공유할 경우, 수집 시점 또는 최초 이용 이전에 소비자에게 별도로 고지하고 명시적 동의를 받아야 함.

(2) 시각적 UI, 음성, 햅틱 등 다양한 고지 수단 적용 방안

■ 몰입형 기기(Immersive Devices)⁸⁾ 및 음성 기반 디바이스의 특성상, 기존 텍스트 중심 고지 방식은 실효성이 낮아 다양한 고지 수단이 요구됨.

8) 몰입형 기기 (Immersive Devices): 이용자의 감각을 몰입시키는 기술 기반 기기로, AR/VR 헤드셋, 스마트글래스, 햅틱 장비 등이 포함됨.

- 시각·음성·촉각 피드백(haptic feedback)을 결합한 다채널 고지 체계를 도입할 수 있도록 제도 개선이 추진됨
 - 시각적 UI: 가상현실 또는 증강현실 콘텐츠 내 오버레이 형태의 고지 창 삽입
 - 음성 안내: 스마트 스피커 및 음성비서 기능 이용 시, 음성 고지를 통한 안내 제공 의무화
 - 햅틱 신호: 진동 또는 촉각 피드백을 통해 정보 수집 시작 시점을 직관적으로 전달
 - 이용자의 물리적 환경 또는 장애 특성을 고려한 대체 수단(예: 텍스트 음성 변환, 색상 대비 조정 등) 병행 적용 권장됨
 - 고지 내용은 간결하되 핵심 정보를 포함하고, 전체 정책은 링크 또는 설정 메뉴를 통해 제공함.

(3) 아동 및 미성년자 대상 서비스의 보호자 동의 및 고지 강화

■ 커넥티드 디바이스 및 증강·가상 현실(AR/VR) 콘텐츠는 아동·청소년이 자주 사용하는 서비스인 만큼, 이들을 위한 별도의 보호 조치가 강화됨.

- 아동 및 미성년자 대상 기기 또는 서비스는 연령 확인 절차를 강화하고, 보호자의 사전 동의를 확보해야 함.
 - 연령 확인은 생체정보 기반 연령 추정, 공공 신분증 확인, 신용카드 결제 등 다중 수단으로 진행 가능
 - 13세 미만 아동의 경우, 아동 온라인 프라이버시 보호법(Children's Online Privacy Protection Act, COPPA)⁹⁾에 따라 보호자의 명시적 동의 확보가 필수임
 - 보호자 고지는 문자, 이메일 또는 연동된 보호자 계정의 알림을 통해 수행하며, 수집 항목, 이용 목적, 저장 기간, 제3자 제공 여부를 포함함
- 아동 대상 서비스는 개인정보 최소 수집 원칙(Data Minimization Principle)¹⁰⁾과 이용 제한 기능 제공 의무(Use Limitation Features Obligation)¹¹⁾를 포함함.
 - 시선 추적, 생체 반응, 행동 분석 등 고위험 개인정보의 수집은 차단되어야 함.
 - 수집된 정보는 보호자의 확인 및 삭제 요청이 가능해야 하며, 30일 이내 처리 완료가 권고됨.
 - 아동이 직접 동의하도록 유도하거나, 동의 거부 시 불이익을 주는 UI는 금지됨.

9) 아동 온라인 프라이버시 보호법 (COPPA): 미국 연방법으로 13세 미만 아동의 개인정보 수집 시 보호자의 사전 동의를 요구함.

10) 개인정보 최소 수집 원칙 (Data Minimization Principle) : 개인정보는 서비스 제공에 직접적으로 필요한 최소한의 범위 내에서만 수집해야 하며, 과잉 수집은 금지됨. 이는 개인정보 보호법의 핵심 원칙으로, 수집 목적에 부합하지 않는 데이터는 저장·이용할 수 없음.

11) 이용 제한 기능 제공 의무 (Use Limitation Features Obligation): 이용자에게 개인정보 사용 범위를 직접 통제할 수 있는 설정 옵션(예: 위치 추적 끄기, 시선 추적 비활성화 등)을 제공해야 하며, 고위험 정보에 대해서는 이용자가 명확히 거부할 수 있는 선택권이 보장되어야 함.

5. CCPA 개정안이 기업 개인정보 거버넌스에 미치는 영향 및 대응 전략

(1) 자동화 기술 도입과 개인정보 보호 거버넌스 변화 분석

■ CCPA 개정안은 ADMT 및 고위험 개인정보 활용이 증가하는 환경에서, 기업의 개인정보 보호 체계를 단순한 컴플라이언스 수준에서 전략적 거버넌스 체계로 전환할 것을 요구함.

- 자동화 기술의 확산은 기업의 데이터 처리 및 분석 방식 전반에 구조적 변화를 유도함.
 - AI 기반 추천 알고리즘, 채용 자동 필터링, 신용 평가 시스템 등은 소비자 권리 침해와 직결되므로, 사전 리스크 평가 및 지속적 점검이 필수임.
 - 데이터 분석 모델의 훈련 데이터에 편향(Bias)이 존재할 경우, 차별적 의사결정 가능성이 있으므로 내부 검토 절차 강화가 필요함.
 - 이러한 기술 활용은 기업의 데이터 책임성과 소비자 신뢰도에 직접적인 영향을 미치므로, 기술 도입 초기부터 개인정보 보호 관점의 통합이 필수임.

(2) 기업의 법적·기술적 책임 강화 및 내부 정책 개선 방안

■ CCPA 개정안은 ‘책임 기반 규제(Responsibility-based Regulation)’¹²⁾로의 전환을 명시하며, 개인정보 수집자 중심이 아닌 개인정보 처리자 전체에 공동 책임 구조를 부여함.

- 법적 책임 측면에서는 소비자 권리 보장과 개인정보 처리 전 과정에 대한 책임 강화를 중심으로 기업의 의무가 확대됨.
- 기술적 책임 측면에서는 개인정보 보호뿐만 아니라 개인정보 처리의 설명 가능성(Explainability)¹³⁾과 투명성(Transparency)¹⁴⁾ 확보가 핵심 요구사항으로 부각됨.
- 내부 정책 개선은 제도 대응력을 높이고 위반 리스크를 줄이기 위한 사전·사후 프로세스 전반의 정비를 의미함.

(3) 향후 CCPA 규제 동향 전망과 기업 대응 전략

12) 책임 기반 규제(Responsibility-based Regulation): 개인정보 처리와 관련된 모든 주체에게 공동 책임과 의무를 부여하는 규제 접근법

13) 설명 가능성(Explainability): 자동화된 의사결정 과정이 이용자에게 이해 가능하도록 구성되는 특성

14) 투명성(Transparency): 처리의 전 과정이 소비자에게 공개되고 검증 가능하도록 보장되는 속성

■ CCPA 개정안은 단기적으로는 캘리포니아주에 국한되지만, 미국 연방 차원의 개인정보 보호 입법 논의 및 타 주의 유사 입법에 영향을 미칠 것으로 전망됨.

- 미국 의회에서는 미국 데이터 프라이버시 및 보호법(American Data Privacy and Protection Act, ADPPA)¹⁵⁾ 제정을 위한 논의가 심화되고 있으며, CCPA 개정안은 그 기준을 선도하는 모델로 간주됨.
- 버지니아(Virginia Consumer Data Protection Act, VCDPA)¹⁶⁾, 콜로라도(Colorado Privacy Act, CPA)¹⁷⁾, 코네티컷(Connecticut Data Privacy Act, CTDPA)¹⁸⁾ 등 다수 주에서 CCPA 개정안과 유사한 소비자 권리 강화 및 자동화된 의사결정 기술 규제를 도입하는 추세가 이어짐.
- 법무, 정보보호, 전략기획 등 관련 부서 간 협업을 통해 국내외 법령 개정 및 정책 이슈를 실시간으로 추적하고, 조직 내부 체계에 반영할 수 있는 체계적 프레임워크 마련이 요구됨.

15) American Data Privacy and Protection Act(ADPPA): 미국 연방 차원의 포괄적 개인정보 보호법 제정을 목적으로 한 법안

16) 버지니아 소비자 데이터 보호법 (VCDPA): 2021년 제정된 버지니아주의 개인정보 보호법으로, 소비자의 데이터 접근·삭제·처리 거부권 등을 보장하며, 기업의 데이터 처리 투명성을 요구함.

17) 콜로라도 개인정보 보호법 (CPA): 2021년 제정된 콜로라도주의 개인정보 보호법으로, 소비자 권리 확대와 함께 기업의 데이터 수집 최소화, 목적 제한, 민감정보 고지 의무 등을 규정함.

18) 코네티컷 데이터 프라이버시법 (CTDPA): 2022년 제정된 코네티컷주의 개인정보 보호법으로, GDPR 및 CCPA와 유사한 구조를 기반으로 소비자의 데이터 주권과 기업의 책임을 강조함.

출처 |

1. California Privacy Protection Agency (CPPA), Board Meeting Materials, (2025.05.)
2. California Office of Administrative Law, CCPA Regulations Update Notice, (2025.06.)
3. Federal Trade Commission (FTC), Children's Online Privacy Protection Rule ("COPPA"), (2024.12.)
4. Future of Privacy Forum (FPF), CCPA and Emerging AI Governance: Trends and Proposals, (2025.03.)
5. International Association of Privacy Professionals (IAPP), CCPA AI-Driven Decision-Making Regulation Summary, (2025.04.)
6. DataGuidance, International Online Age Verification Legislative Developments, (2024.06.)
7. World Economic Forum (WEF), Responsible AI Governance in the Age of Automation, (2024.09.)
8. OECD, Children in the Digital Environment: Privacy and Age Verification Tools, (2023.11.)
9. Electronic Frontier Foundation (EFF), Biometric Privacy and Algorithmic Accountability in California, (2025.02.)
10. Stanford Cyber Policy Center, California Privacy Reform Tracker: From CPRA to CCPA 2.0, (2025.01.)
11. Brookings Institution, Risks and Accountability in Automated Decision-Making, (2024.08.)
12. Center for Democracy & Technology (CDT), Privacy and Security Issues in Extended Reality (XR) Platforms, (2025.03.)
13. National Institute of Standards and Technology (NIST), Risk Management Framework for AI Systems, NIST AI RMF 1.0, (2023.01.)
14. European Commission, Comparative Study on EU GDPR and U.S. State Privacy Laws, (2024.10.)
15. UCLA Institute for Technology, Law & Policy, California's Evolving Privacy Law: Analysis of CPPA Draft Amendments, (2025.05.)

신기술

미국 인공지능 거버넌스 법제 동향

[목 차]

1. 미국 연방 AI 거버넌스 입법의 배경 및 정책 방향
 - (1) ‘One Big Beautiful Bill Act’ 제정 배경 및 의의
 - (2) 연방 우선주의 확립과 AI 규제 일원화 흐름
2. 법안 주요 내용 및 개인정보 보호 체계 변화
 - (1) 고위험 AI 시스템에 대한 주정부 규제 범위 조정
 - (2) 연방 차원의 프라이버시 및 설계 기준 정립
3. 구조적 영향 : 개인정보 보호와 규제권의 재편
 - (1) 주법 기반 감독·규제권 약화 우려
 - (2) 데이터 처리 기준의 통일성과 사각지대 확대
4. 기업의 규제 대응 전략 변화
 - (1) 연방 규제 중심의 컴플라이언스 전략 재편
 - (2) 산업계의 법제 대응 및 기술 설계 기준 강화
5. 국내 정책 시사점
 - (1) 개인정보 영향평가(PIA)의 민간 부문 확대
 - (2) 개인정보 보호와 기술혁신의 균형 전략 모색

1. 미국 연방 AI 거버넌스 입법의 배경 및 정책 방향

- (1) ‘미국의 자동화 및 인공지능 표준에 관한 통합법(One Big Beautiful Bill Act)’ 제정 배경 및 의의

■ 미국 연방정부는 AI 기술의 급속한 확산과 주별 상이한 규제 환경으로 인한 법적 혼선을 해소하고자, 2025년 5월 ‘미국의 자동화 및 인공지능 표준에 관한 통합법(One Big Beautiful Bill Act)’¹⁹⁾을 제정함.

19) 미국의 자동화 및 인공지능 표준에 관한 통합법(One Big Beautiful Bill Act): 2025년 미국 하원에서 통과된 AI 규제 통합법으로, 향후 10년간 주정부의 고위험 AI 시스템에 대한 규제를 제한하고 연방정부 주도의 AI 거버넌스 체계를 구축함. 연방 우선주의(Federal Preemption)를 원칙으로 하여 개인정보 보호, 설계 기준, 알고리즘 투명성 등에 대한 통일된 기준 마련을 추진함.

- 해당 법안은 AI 관련 연방 차원의 기준을 수립하여 기업 운영의 예측 가능성을 높이고, 기술 혁신을 지원하는 제도적 기반 마련을 주요 목표로 설정함.
 - 초기 법안에는 10년간 고위험 AI 시스템에 대한 주정부 규제 권한을 제한하는 모라토리엄 조항 (moratorium clause)²⁰⁾이 포함되어 있었으나, 2025년 7월 1일 상원 표결(찬성 99표, 반대 1표)을 통해 해당 조항이 삭제됨.
 - 이로써 AI 관련 소비자 보호, 자동화된 결정 시스템, 로보콜 등에 대한 주정부의 입법 및 감독 권한이 일정 수준 회복됨.
- 법안은 연방정부가 개인정보 보호, 설계 기준, 알고리즘 투명성 등에 대한 통일된 규제 프레임워크를 마련하도록 규정함.
 - 자동화된 의사결정 시스템(Automated Decision-Making System, ADMS)²¹⁾, 생체인식 기술, 위험도 기반 알고리즘 등 고위험 기술군을 대상으로 연방 차원의 가이드라인을 개발하도록 명시함.
 - 주정부는 고위험 AI 기술에 대해 보완적 또는 영역 제한적 규제 권한을 유지할 수 있도록 조정됨.
- 본 법안은 기술 경쟁력 확보와 소비자 권리 보호의 균형을 도모하는 방향으로 최종 확정되었으며, 향후 연방-주 간 역할 분담을 기반으로 하는 협력형 AI 거버넌스 체계 구축이 기대됨.

(2) 연방 우선주의 확립과 AI 규제 일원화 흐름

■ 법안은 AI 관련 법·제도의 통일성과 예측 가능성을 제고하기 위해 연방정부 중심의 규제 체계 수립을 추진하였으며, 법안 초안에서는 고위험 AI 시스템에 대한 주정부의 입법 권한을 제한하는 연방 우선주의(Federal Preemption)²²⁾ 원칙이 적용되었음.

- 기존에는 캘리포니아, 일리노이 등 일부 주에서 프라이버시 보호, 알고리즘 책임성, ADMS 규제 등을 독자적으로 입법·운영해 왔음.
 - 예를 들어, 캘리포니아 개인정보보호법(California Privacy Rights Act, CPRA)²³⁾과 일리노이 생체정보보호법(Biometric Information Privacy Act, BIPA)²⁴⁾은 민감정보 보호 및 자동화 기술 통제의 대표적인 주법 사례로 꼽힘.

20) 모라토리엄 조항(moratorium clause): 법이나 규제의 적용을 일정 기간 유예하거나 잠정 중단하는 조항.

21) 자동화된 의사결정 시스템(Automated Decision-Making System, ADMS): 알고리즘이나 AI가 인간의 개입 없이 독립적으로 결정을 내리는 기술 또는 절차

22) 연방 우선주의(Federal Preemption) 원칙: 미국 연방법이 주법에 우선하도록 하는 원칙

23) CPRA (California Privacy Rights Act): 캘리포니아주의 개인정보 보호법으로, 민감정보 보호 및 자동화된 의사결정에 대한 소비자 권리를 명시. 이번 연방법 통과로 일부 조항의 효력 약화 가능성 제기됨

24) BIPA (Biometric Information Privacy Act): 미국 일리노이주에서 제정된 생체정보 보호법으로, 지문·얼굴·홍채 등 생체정보 수집 시 사전 동의, 목적 명시, 보관 기간 제한 등을 의무화하고 위반 시 민사 소송을 허용함.

- 이러한 주별 규제는 AI 채용 도구, 신용평가 알고리즘, 감시 시스템 등에서 상이한 기준을 적용하여 기업의 운영 부담과 규제 충돌을 야기함.
- 이에 따라 연방정부는 AI 기술을 국가 경쟁력 핵심 인프라로 규정하고, 분산된 규제 환경의 중앙집중화를 추진함.
 - 법안 초안에서는 고위험 AI 기술군에 대해 연방정부가 기준을 정하고, 주정부는 별도의 규제를 둘 수 없도록 제한함.
 - 그러나 상원 논의 과정에서 소비자 보호·로보콜 규제·아동 안전 등 주정부 역할의 필요성이 부각되면서 조항이 조정됨.
- 2025년 7월 상원은 해당 법안에서 10년간 주정부 규제를 금지하는 모라토리엄 조항을 삭제하였으며, 이로 인해 주정부는 일정한 범위 내에서 소비자 보호 및 고위험 기술 규제에 관한 입법·감독 권한을 유지하게 됨.
 - 캘리포니아 법무장관 Rob Bonta와 아칸소 법무장관 Tim Griffin 등은 상원 투표 직후, “AI 기술의 안전한 사용과 소비자 권리 보호를 위해 주정부의 독립적 규제는 반드시 필요하다”고 공동 성명을 발표함.
 - 최종 법안은 연방 기준을 중심으로 하되, 주정부가 보완적 역할을 수행할 수 있는 절충형 구조로 조정됨.

2. 법안 주요 내용 및 개인정보 보호 체계 변화

(1) 고위험 AI 시스템에 대한 주정부 규제 범위 조정

- 법안은 고위험 AI 시스템에 대한 규제 권한을 연방정부에 부여하되, 2025년 7월 상원 수정안 반영을 통해 주정부가 일정 영역에서 규제·감독 권한을 유지할 수 있도록 조정됨.
- 고위험 AI 시스템은 생체인식 감시, 자동화된 채용·평가 시스템, 금융·의료 분야의 알고리즘 기반 의사결정 시스템 등 개인의 권리와 사회적 안전에 중대한 영향을 미칠 수 있는 기술군으로 정의됨.
 - 기존에는 캘리포니아, 일리노이 등 주법에서 해당 기술군에 대한 별도 보호 조항과 통제 규정을 운영해 왔음.
 - 초기 법안은 이러한 주정부의 규제권을 제한하는 내용을 포함했으나, 상원에서의 수정 통과로 연방·주정부 간 규제 권한이 재조정됨.

- 최종 법안은 고위험 기술의 정의와 기본 규제 프레임워크를 연방 차원에서 통일적으로 설정 하되, 주정부는 로보콜 대응, 아동 보호, 소비자 정보 감시 등의 영역에서 보완적 입법이 가능하도록 함.
 - 특히 ADMS와 생체정보 시스템의 활용에 있어, 주정부는 자율적으로 투명성·설명 책임 강화 조치할 수 있음.
- 기업은 연방 기준에 따라 AI 시스템의 설계와 운영을 일원화할 수 있으나, 소비자 보호 관련 규제가 주별로 병존할 수 있으므로 이중 컴플라이언스 전략이 요구됨.
 - 상위 규범으로서 연방 기준이 존재하지만, 특정 소비자 보호 조항에서는 지역적 특수성과 법적 우선순위에 따라 주법 적용 가능성이 남아 있음.
 - 이에 따라, 고위험 AI 기술 도입 시 연방·주법의 교차점에 대한 법적 해석 및 대응체계 마련이 중요함.

(2) 연방 차원의 프라이버시 및 설계 기준 정립

■ 법안은 AI 시스템 전반에 적용되는 프라이버시 보호 원칙과 설계 기준을 연방 차원에서 통일적으로 마련하고자 함.

- 연방정부는 개인정보 보호 요소를 시스템 개발 초기부터 반영하는 ‘개인정보 보호 중심 설계 (Privacy by Design)’²⁵⁾ 원칙을 기반으로, AI 시스템 설계 및 운영 전 과정에서의 책임성과 안전성 확보를 정책 기조로 설정함.
 - 이에 따라, AI 시스템이 자동화된 의사결정을 수행하는 경우, 정보주체에게 영향을 미치는 판단의 존재를 사전에 통지할 의무를 부과함.
 - 설계 단계부터 데이터 최소화, 목적 제한성, 민감정보 취급 제한 등 원칙을 내재화하는 기술적 요건이 포함됨.
- 향후 연방정부는 ‘고위험 AI 시스템 가이드라인’을 마련하고, 이에 알고리즘 투명성, 설명 책임, 설계 기준, 위험 영향 평가 등을 포함할 예정임.
 - 가이드라인은 미국 국립표준기술연구소(National Institute of Standards and Technology, NIST), 미국 백악관 예산관리국(Office of Management and Budget, OMB), 미국 연방거래위원회(Federal Trade Commission, FTC) 등 연방기관 협업 하에 개발 중이며, 법적 구속력은 없지만 연방기관 및 민간 기업의 규제 준수 참고 기준으로 사용될 전망이다.

25) Privacy by Design (설계단계부터의 개인정보 보호): 시스템 개발 초기부터 개인정보 보호 요소를 설계에 반영하는 원칙. 이번 법안에서는 AI 시스템의 안전성과 책임성을 확보하는 주요 접근 방식으로 강조됨.

- 미국 개인정보 및 시민자유 감독위원회(Privacy and Civil Liberties Oversight Board, PCLOB) 등 관련 기구와 연계한 감시 체계 구축도 병행 검토 중임.
- 다만, 연방 차원의 프라이버시 기준은 일부 주법이나 EU의 GDPR에 비해 기업 친화적일 가능성이 있다는 우려가 제기되고 있음.
 - 예를 들어, 민감정보 처리 시 명시적 동의 요건이 완화되거나, 자동화된 결정에 대한 인적 개입 보장 조항이 삭제될 가능성 등이 논의됨.
 - 이로 인해 정보주체 권리의 후퇴, 사전 위험성 평가 생략, 감시 기술 남용 가능성 등에 대한 우려가 제기됨.
- 그럼에도, 연방 기준은 기술 설계단계에서 프라이버시 보호를 내재화하고, 국가 단위의 통일된 대응체계와 기업의 규제 준수 부담 완화라는 실익을 제공함.
 - 기업은 단일 기준으로 내부 규정과 개발 절차를 표준화할 수 있으며, 이를 통해 글로벌 규제 대응 및 대외 신뢰성 확보 측면에서도 긍정적 효과를 기대할 수 있음.

3. 구조적 영향 : 개인정보 보호와 규제권의 재편

(1) 주법 기반 감독·규제권 약화 우려

■ 법안은 연방정부 중심의 규제 일원화를 지향하였으나, 최종적으로는 주정부의 입법 및 감독 권한이 일부 보장되는 형태로 조정되었으며, 이에 따라 기존 주법 체계와의 관계 재조정이 불가피하게 됨.

- 미국은 주정부 중심의 분산형 개인정보 보호 체계를 유지해왔으며, 주요 주들이 고위험 기술 규제에 선도적 역할을 해왔음.
 - 미국은 개인정보 보호를 주정부 주도의 분산형 체계로 발전시켜 왔으며, 캘리포니아, 일리노이, 콜로라도, 버지니아 등 주요 주들이 자체 법령을 통해 고위험 기술 통제와 정보주체 권리 보호를 선도해 왔음.
 - 각 주의 법령은 사전 동의 요건, 설명받을 권리, 민감한 개인정보 보호 강화 등 독자적 보호 장치를 포함하고 있음.
- 연방 법안 초안에 포함된 모라토리엄 조항에 대해 40개 주 법무장관이 삭제를 요구하며 주정부 규제권의 필요성을 강조함.
 - 연방 정부는 AI 규제의 통일성을 위해, 고위험 AI 기술에 대한 주정부 규제 권한을 10년

간 제한하는 'AI 규제 모라토리엄 조항'을 법안 초안에 포함했음.

- 이에 대해 캘리포니아 법무장관 Rob Bonta와 아칸소 법무장관 Tim Griffin 등 40개 주 법무장관은 연대 서한을 통해 조항 삭제를 공식 촉구하며 주정부의 개입 필요성을 강조함.
- 상원은 모라토리엄 조항을 삭제하고, 고위험 AI 기술에 대한 주정부의 규제·감독 권한을 일부 회복시킴.
 - 2025년 7월, 상원 표결(찬성 99표, 반대 1표)을 통해 모라토리엄 조항은 최종 삭제되었으며, 이로써 주정부는 고위험 AI 기술에 대한 일정한 입법 및 감독 권한을 다시 확보함.
 - AI 기반 로보콜, 딥페이크, 자율주행 시스템 등 분야에서 주정부의 독립적 규제가 가능해졌으며, 연방 기준을 보완하는 역할을 수행할 수 있게 되었음.
- 연방 기준이 과도하게 완화될 경우, 지역 보호 수준이 낮아지고 소비자 권리가 약화될 우려가 있음.
 - 연방 기준은 산업계와 정치권의 절충에 따라 기준 완화 가능성이 크며, 이로 인해 전체적인 개인정보 보호 수준이 낮아질 수 있다는 지적이 제기되고 있음.
 - 기준이 완화될 경우, 지역 특화 규제나 윤리적 기준이 희생될 수 있으며, 시민사회 기반의 감시 역량도 위축될 우려가 있음.
- 연방-주 간 협력체계 구축이 개인정보 보호의 실효성과 정책 조정의 핵심 과제로 떠오르고 있음.
 - 향후에는 연방-주 간 역할 분담을 기반으로, 다층적이고 유연한 규제 체계를 구축할 필요가 있음.
 - 지역 참여형 심의기구, 규제 조정 협의체 등 지방정부와의 협력적 거버넌스 모델이 주요 정책 과제로 부상하고 있음.

(2) 데이터 처리 기준의 통일성과 사각지대 확대

■ 연방 기준은 AI 관련 데이터 처리의 일관성과 명확성 제고에 기여할 수 있으나, 동시에 특정 기술군에 대한 규제 사각지대 발생 가능성도 함께 내포하고 있음.

- 기업은 연방 기준을 중심으로 AI 시스템을 설계·운영할 수 있게 되며, 이로 인해 규제 준수 부담 완화, 운영 효율성 향상, 기술 도입 속도 개선 등의 효과가 기대됨.
 - 특히 다국적 기업, 플랫폼 사업자, 클라우드 기반 AI 개발사는 단일 기준 적용을 통해 규제 리스크를 최소화하고 글로벌 확산 전략을 수립할 수 있음.
 - 중복 규제를 피할 수 있게 되면서, 기업의 컴플라이언스 비용 절감 효과도 예상됨.

- 그러나 연방 기준이 산업별 특수성이나 위험 요소를 충분히 반영하지 못할 경우, 고위험성이 있음에도 규제 대상에서 제외되는 기술군이 발생할 수 있음.
 - 예를 들어, AI 기반 감정 분석, 추천 알고리즘, 행동 예측 모델 등은 법령상 ‘고위험 기술’로 명시되지 않는 경우 규제 대상에서 벗어날 수 있음.
 - 이로 인해 정보주체는 자동화된 결정의 영향을 받더라도 설명을 요구하거나 통지를 받을 권리를 보장받지 못할 위험이 존재함.
- 또한, 연방정부가 모든 기술군에 대해 균등한 감독 역량을 갖추지 못한 상황에서, 연방 일원화가 즉각적인 보호 효과로 이어지기 어렵다는 지적도 제기됨.
 - 연방기구(NIST, FTC, OMB 등)의 기술 이해도와 감독 체계가 기술 발전 속도를 따라가지 못할 경우, 규제 공백 및 사각지대가 제도적으로 고착화될 우려가 있음.
 - 이에 따라, 업계 자율규제, 외부 감사, 윤리위원회 등 보완적 거버넌스 장치 마련이 병행되어야 함.

4. 기업의 규제 대응 전략 변화

(1) 연방 규제 중심의 컴플라이언스 전략 재편

■ 법안 통과로 인해 미국 내 기업들은 기존의 주별 데이터·AI 규제 대응 방식에서 벗어나, 연방 기준을 중심으로 한 통합 컴플라이언스 전략으로 전환하는 움직임을 보이고 있음.

- 기존에는 각 주의 개인정보보호법과 AI 관련 규제에 따라 기업이 지역별로 상이한 내부 정책과 기술 대응을 병행해야 했음.
 - 예를 들어, 일리노이주에서는 생체정보 처리 시 별도 동의가 필요하고, 캘리포니아주는 자동화된 의사결정에 대한 설명 제공을 요구해 왔음.
 - 이로 인해 중견·대기업들은 AI 시스템 설계 단계에서부터 주법별 사전 검토 및 위험 분산 전략 수립이 필수였음.
- 연방 기준이 마련되면서 기업은 단일한 법적 프레임워크에 따라 AI 시스템을 설계·운영할 수 있게 되었으며, 이로 인해 법적 예측 가능성 확보, 설계 효율성 향상, 리스크 집중 관리가 가능해짐.
 - 많은 기업들이 ‘사전 컴플라이언스 설계(Compliance by Design)²⁶⁾’ 방식을 도입하여, 개발 초기 단계에서부터 연방 기준을 반영한 설계 구조를 마련 중임.

26) 사전 컴플라이언스 설계 (Compliance by Design): AI 기술 개발 초기부터 법률 준수를 고려한 구조를 설계하여, 사후 리스크를 최소화하는 기업 전략.

- 내부 정책, 교육 체계, 감사 기록 유지, 로그 분석 등도 연방 요건에 맞게 표준화되는 추세임.
- 일부 대기업은 AI 책임성 위원회(AI Accountability Committee)를 신설하거나, 외부 자문 기관을 통한 연방-주 기준 정합성 검토 체계를 운영 중임.
 - AI 시스템의 리스크 영향 평가, 윤리성 점검, 설명 가능성 확보 등이 기업 컴플라이언스의 핵심 항목으로 부상하고 있음.
 - 특히 글로벌 기업은 EU GDPR, 캐나다 인공지능 및 데이터법(Artificial Intelligence and Data Act, AIDA)²⁷⁾ 등 해외 규제와의 연계성도 고려하여 다층적 규제 대응 전략을 수립 중임.
- 그러나 연방 기준에 대한 의존도가 높아질수록, 기준이 완화되거나 변화할 경우 전체 컴플라이언스 체계의 유연성이 저하될 수 있음.
 - 이에 따라, 연방 기준 외에도 업계 자율규제, 윤리 가이드라인, 국제 기준 정합성 등을 함께 고려하는 혼합형 전략 수립이 권장됨.

(2) 산업계의 법제 대응 및 기술 설계 기준 강화

■ 연방정부 주도의 AI 규제 일원화 흐름은 산업계 전반에 기술 설계 방식 변화와 법제 대응 전략 고도화를 유도하고 있음.

- 주요 기술 기업들은 연방 기준 준수를 전제로, AI 시스템 설계 초기 단계부터 법적 요건을 반영한 내부 지침을 수립하고 있음.
 - 예를 들어, 개인정보를 수집·처리하는 AI 모델에는 데이터 최소화, 정보주체 통지 의무, 투명성 확보 요건을 포함시키고 있음.
 - 고위험 기술군(예: 자동화된 신용 분석, 행동 예측, 얼굴 인식 기술 등)에 대해서는 사전 영향평가 및 보안 감사 절차를 병행 적용하는 방향으로 기술 지침을 강화하고 있음.
- 산업계는 연방 규제 프레임워크가 지나치게 경직되거나, 기술 발전을 제약하지 않도록 하기 위해 연방정부와의 정책 협의 채널을 적극 활용하고 있음.
 - 일부 빅테크 기업은 산업 연합체 및 자율규제기구를 통해 연방 기준에 대한 현실 반영 요구를 제기하고 있음.

27) AIDA (Artificial Intelligence and Data Act): 캐나다 정부가 제안한 법안으로, 고위험 AI 시스템의 투명성, 책임성, 안전성을 확보하기 위한 규제 체계를 마련하고 기업의 데이터 활용 및 알고리즘 운영에 법적 책임을 부과함.

- 이에 따라, 기업 내 AI 거버넌스 조직이 법무·정책·기술이 결합된 융합형 구조로 재편되고 있음.
- AI 기술이 다양한 산업 분야에 확산됨에 따라, 법적 리스크, 소비자 권리 침해, 국제 기준 충돌 등을 사전에 방지하기 위한 선제적 기술·법제 대응 전략 수립이 산업계의 필수 과제로 부상하고 있음.
- 기업은 책임소재 분쟁 대비, 감사 및 보고 체계 정비, 글로벌 인증 체계 연계 등을 통해 AI 기반 제품 및 서비스에 대한 사회적 신뢰 확보에 주력하고 있음.

5. 국내 정책 시사점

(1) 개인정보 영향평가(PIA)의 민간 부문 확대

■ 미국 CCPA 개정안의 ADMT·고위험 기술군에 대한 사전 위험 평가 의무화 명시를 고려할 때 한국도 PIA 제도의 민간 확대를 검토할 필요 있음

- 한국은 현재 PIA 제도를 공공기관 신규 사업·시스템 도입에 한정하여 운영하고 있으며, 민간 기업은 자율적으로 적용
 - 그러나 의료, 금융, 교통, 교육 등 고위험 AI 활용 산업에서 개인정보 대규모 수집·처리가 늘어남에 따라, 민간 부문에 대해서도 정기적·의무적 PIA 수행을 제도화할 필요 있음
 - 이를 통해 기업은 데이터 최소화, 편향 점검, 설명 가능성 확보, 보안 취약점 관리를 사전에 수행할 수 있으며, 감독기관은 이를 근거로 위험 완화·이행 점검을 강화할 수 있음
- 정책적 추진 방향은 다음과 같이 제시될 수 있음.
 - (단계적 의무화) 우선 대규모 데이터 처리 기업·플랫폼부터 적용 후, 중소기업으로 점진 확대
 - (평가 도구·가이드라인 제공) 민간기업의 부담 완화를 위해 표준화된 PIA 프레임워크·교육 지원 제공
 - (감독·보고 체계 정비) 평가 결과를 감독기관에 보고하고, 정기적 보안 감사·위험평가와 연계
- 결론적으로, PIA 민간 확대는 사전 예방적 위험 관리 체계 구축의 핵심이며, AI 시대 개인정보 보호를 강화하면서 기업 신뢰와 국제 정합성 확보에도 기여할 수 있음.

(2) 개인정보 보호와 기술혁신의 균형 전략 모색

■ 미국의 AI 규제 일원화 흐름은 기술혁신 촉진과 개인정보 보호 기준 약화 우려라는 양면적 함의를 보여주며, 국내에서도 균형 잡힌 규제 설계 필요성을 제기하고 있음.

- AI 기술이 의료, 금융, 행정 등 고위험 분야에 빠르게 확산되면서, 과도한 개인정보 수집·처리·분석에 대한 사회적 우려가 증가하고 있음.
 - 생성형 AI, 감정 예측, 실시간 얼굴 인식 등은 사생활 침해 및 정보 주체 권리 침해 가능성이 높음.
 - 반면, 과도한 사전 규제는 신기술 도입 저해, 기업 경쟁력 약화, 국제 표준과의 괴리를 초래할 수 있음.
- 국내 정책은 정보주체 보호와 기술 유연성 간 균형 달성을 위해 정밀하고 예측 가능한 규제 설계 원칙을 기반으로 재정비되어야 함.
 - 특히, 위험 기반 차등 규제(Risk-Based Regulation)²⁸⁾ 적용을 통해 기술 위험도에 따라 규제 강도를 차별화하는 방식이 필요함.
 - 개인정보 보호 요소를 시스템 설계 단계부터 반영하는 개인정보 보호 중심 설계(Privacy by Design) 원칙의 의무화가 핵심 전략으로 떠오르고 있음.
 - 개인정보 영향평가(Privacy Impact Assessment, PIA) 제도²⁹⁾는 공공 중심에서 민간 부문까지 확대 적용되어, AI 시스템 개발 초기부터 위험요소를 식별하고 대응 방안을 마련하는 수단으로 활용될 필요가 있음.
 - 또한, AI 윤리 가이드라인의 실효성을 높이기 위해서는 민관학 협력 기반의 윤리 거버넌스를 강화하고, 시민 참여와 자율규제를 연계한 실행력 중심의 정책 설계가 요구됨.
- 국내는 글로벌 경쟁력을 유지하면서도 정보주체 권리와 사회적 신뢰를 확보할 수 있도록, 유연하면서도 견고한 조율형 규제 프레임워크 구축이 요구됨.

28) 위험 기반 차등 규제(Risk-Based Regulation): 기술의 위험도에 따라 규제 강도를 달리 적용하는 방식으로, 고위험 기술에는 강화된 사전 평가와 관리가 요구됨.

29) 개인정보 영향평가(PIA): 새로운 기술이나 시스템이 개인정보에 미치는 영향을 사전에 분석하고 대응 방안을 마련하는 제도. 국내에서는 공공 부문 중심으로 운영되고 있으며, 민간 부문 확대 필요성이 제기됨.

출처 |

1. Law and the Workplace, Big Beautiful Bill leaves AI regulation to states and localities—for now (2025.07.03.)
2. Sheppard Mullin Health Law Blog, The OBBB Act's Proposed Moratorium on State AI Legislation—What Healthcare Organizations Should Know (2025.06.20.)
3. AP News, Senate drops state-level AI moratorium from Trump's tech bill ahead of July 4 signing (2025.07.01.)
4. Future of Privacy Forum (FPF), U.S. State Privacy Legislation Tracker (Updated 2025.05)
5. OECD.AI, U.S. Regulatory Landscape for AI: Trends and Federal Proposals (2025.04.18.)
6. Brookings Institution, Regulating AI in the United States: Federalism, Fragmentation, and the Future (2025.03.10.)

개인정보 월간동향분석

「2025 개인정보 월간동향분석 보고서」는
개인정보보호위원회의 출연금으로 수행한 사업의 결과물입니다.

한국인터넷진흥원의 승인 없이 본 보고서의 무단전재나 복제를 금하며,
인용 출처 「2025 개인정보 월간동향 분석보고서」를 밝혀주시기 바랍니다.

본 보고서의 내용은
한국인터넷진흥원의 공식 견해가 아님을 알려드립니다.

PRIVACY REPORT

